THOMSON COURSE TECHNOLOGY

Guide to Network Defense and Countermeasures Third Edition

Chapter 13

Security Policy Design and Implementation

Objectives

- Describe the system development life cycle
- Explain the fundamental concepts of risk analysis
- Describe different approaches to risk analysis
- Explain the process of risk analysis
- Describe techniques to minimize risk

© Cengage Learning 2014

Understanding the Security Policy Life Cycle, Part 1

- Development of a security policy follows a life cycle
- Constant changes in information security means a security policy is never truly complete
- Four phases of system development life cycle:
  - Needs assessment
  - System design
  - System implementation
  - Performance monitoring

© Cengage Learning 2014

The System Development Life Cycle

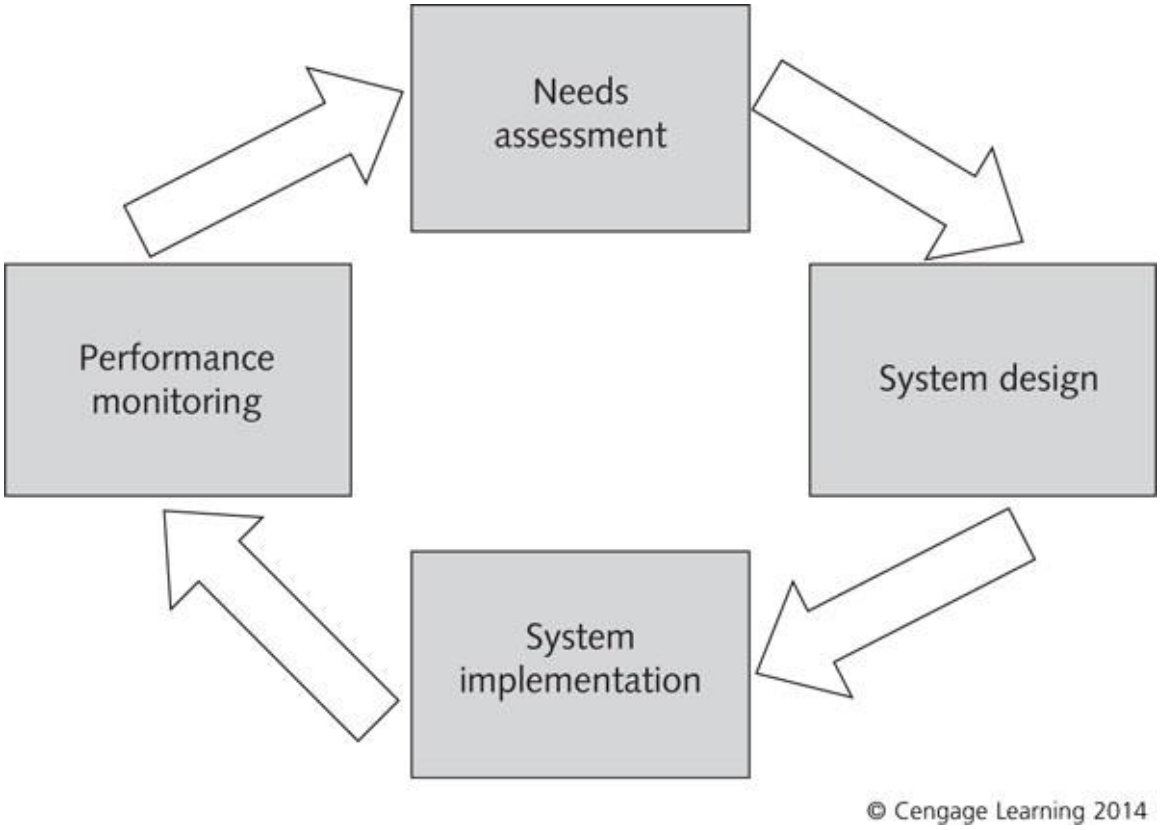


Figure 13-1 The system development life cycle

Understanding the Security Policy Life Cycle, Part 2

- Needs Assessment
  - Purpose of system or project must be made clear
  - Standards for success must be established
- System Design
  - Planning a system that addresses needs
  - Incorporate essential system elements at the beginning of a project rather than add them later
  - A system of checks and balances should be put into place

© Cengage Learning 2014

Understanding the Security Policy Life Cycle, Part 3

- System Implementation
  - Training should take place before implementation
  - Depending on project, a system might be implemented in a pilot phase and activated with only a limited scope
    - Security policies are generally rolled out in stages
- Performance Monitoring
  - Ask several questions: Are any of the assumptions made while developing no longer true? Have new developments required modification of the policy? Are employee compliant? Are manager enforcing compliance?
  - May need to return to needs assessment phase

© Cengage Learning 2014

Examining the Concepts of Risk Analysis, Part 1

- Asset: person, thing, or idea that supports the company's mission
  - Employees, servers, data, and intellectual property
- Threat: person or occurrence that could damage an asset
  - Hackers, user errors, and acts of nature
- Vulnerability: a weakness or an exposure that can make an asset more susceptible to risk
  - Unpatched Web server or a patched Web server (exposed to untrusted systems on the Internet)

© Cengage Learning 2014

Examining the Concepts of Risk Analysis, Part 2

- Risk: probability that a threat will cause damage to an asset
- Risk analysis
  - Determines the threats that face the organization, the assets that are at risk, and the priority that should be given to each resource
- Security policy: statement that spells out
    - What defenses should be configured
    - How the organization will respond to attacks
    - How employees should safely handle the organization's resources

© Cengage Learning 2014

The Risk Analysis Life Cycle

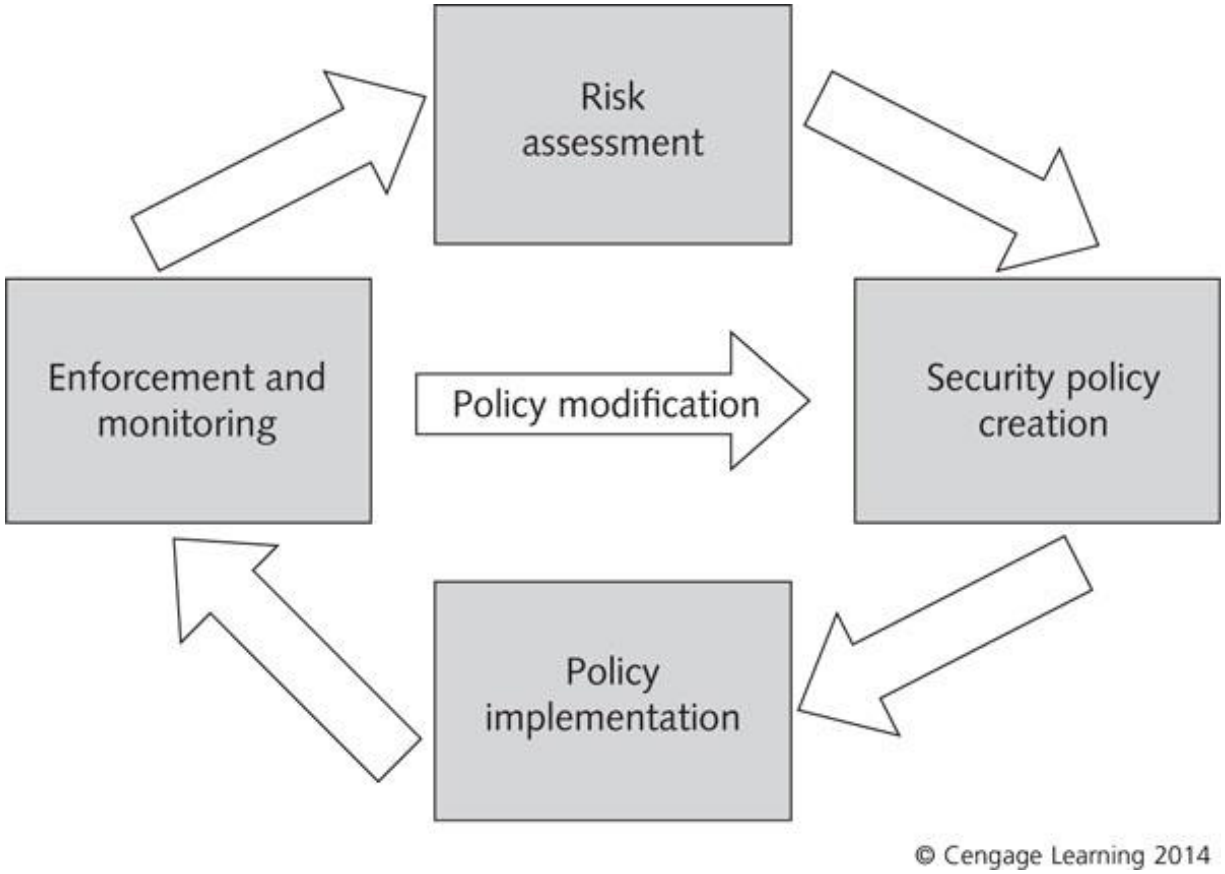


Figure 13-2 The risk analysis life cycle

Risk Analysis Factors, Part 1

- Risk analysis
  - Should encompass hardware, software, and data warehouses
  - Factors needed to create a risk analysis:
    - Assets, Threats, Probabilities, Vulnerabilities, Consequences, Security controls
- Assets
  - Physical assets
  - Data assets
  - Software assets
  - Personnel assets

© Cengage Learning 2014

Risk Analysis Factors, Part 2

- Threats
  - Events that have not occurred but might occur
  - Presence of a threat increases risk
  - Can be universal or specific to your systems
  - Circumstance-specific threat examples
    - Power supply
    - Crime rate
    - Facility
    - Industry
  - The seriousness of a threat depends on the probability that it will occur

© Cengage Learning 2014

Risk Analysis Factors, Part 3

- Probabilities
  - Factors that affect the probability that a threat will actually occur
    - Geographic - earthquakes
    - Physical location – electrical problem
    - Habitual – employees leaving written passwords exposed
  - Exposure
    - Increases if you have factors that increase threat probabilities
  - Probability of threats is often assessed and recorded in general terms

© Cengage Learning 2014

Sample Threat Probabilities

Threat	Probability
Earthquake	Medium
Fire	Low
Flood	High
Attack from the Internet	Very high
Virus infection	Very high
Employees giving out information	Low

Table 13-1 Sample threat probabilities

© Cengage Learning 2014

Risk Analysis Factors, Part 4

- Vulnerabilities
  - Situations or conditions that increase a threat probability
    - Which in turn increases risk
  - Examples
    - Connecting computers to the Internet
    - Keeping computers in open areas
    - Installing Web servers outside the corporate network
    - Application software flaws
    - Poorly configured firewalls or packet filters
    - Unprotected passwords and log files
    - Wireless networks

© Cengage Learning 2014

Risk Analysis Factors, Part 5

- Consequences
  - Significance of an attack impact
  - Some consequences can be estimated
  - Some consequences are difficult to anticipate
- Cost-benefit analysis: estimate of the cost of the investment and its benefit to the company
- Critical for management to understand:
  - Actual costs paid per year by the company because of security incidents
  - Benefit is the amount per year saved by preventing these incidents

© Cengage Learning 2014

Probabilities and Consequences of Threats

Threat	Probability	Consequences
Earthquake	Medium	Significant
Fire	Low	Significant
Flood	High	Minor
Attack from the Internet	Very high	Serious
Virus infection	Very high	Serious
Employees giving out information	Low	Significant

Table 13-2 Probabilities and consequences of threats

© Cengage Learning 2014

Risk Analysis Factors, Part 6

- Security Controls
  - Countermeasures you can take to reduce threats
  - Examples include
    - Firewalls and IDPSs
    - Locking doors
    - Using passwords and encryption
  - Residual risk
    - What is left over after countermeasures are implemented

© Cengage Learning 2014

Countermeasures

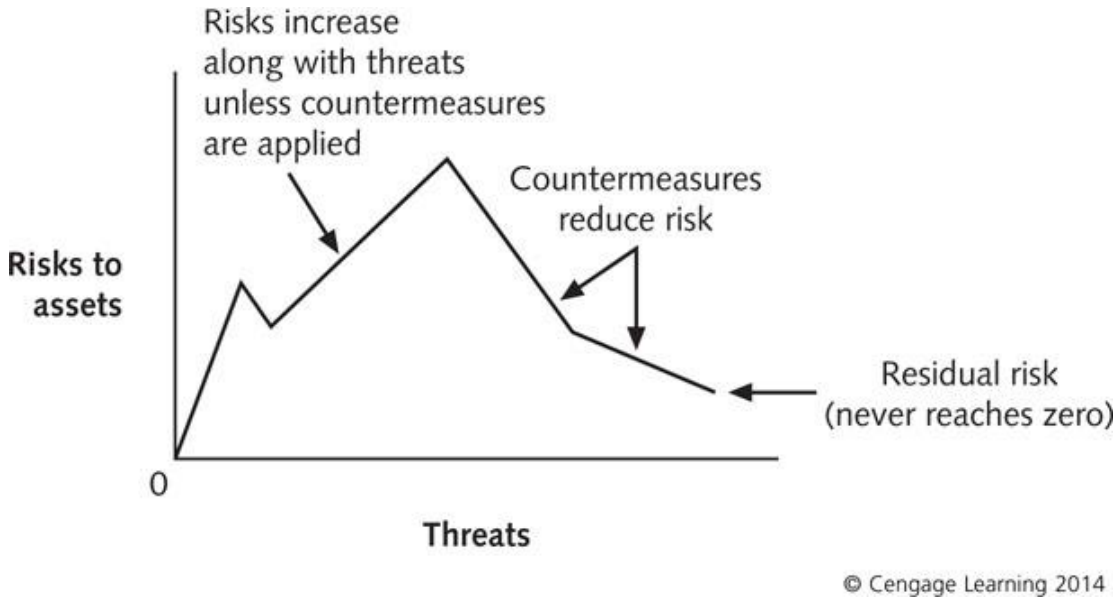


Figure 13-3 Countermeasures reduce but never eliminate risk

© Cengage Learning 2014

Risk Analysis Methods

- You can use different methods of risk analysis to create a security policy
  - You can then evaluate how well the policy is performing
- Two risk analysis methods:
  - Survivable Network Analysis (SNA)
  - Threat and Risk Assessment (TRA)

© Cengage Learning 2014

Survivable Network Analysis, Part 1

- Survivable Network Analysis (SNA): security process developed by the CERT Coordination Center
- Assumes that a system will be attacked
  - Leads you through a four-step process designed to ensure the survivability of a network
- Key properties of a network
  - Resistance
  - Recognition
  - Recovery
  - Adaptation and evolution

© Cengage Learning 2014

Survivable Network Analysis, Part 2

- Fault tolerance
  - Ability of an object or a system to continue operations despite a failure
- SNA steps
  - System definition – create an overview of the system's organizational requirements
  - Essential capability definition – identify a system's essential services and assets critical to fulfill goals
  - Compromisable capability definition – design system intrusions and then trace the intrusion through system architecture to identify vulnerabilities
  - Survivability analysis – identify potential faults in system and make recommendations for correction

© Cengage Learning 2014

Threat and Risk Assessment

- TRA approaches risk analysis from the standpoint of threats and risks to an organization's assets
  - Also consequences if those threats occur
- TRA steps
  - Asset definition – identify what you need to defend
  - Threat assessment – identify threats that place asset at risk
  - Risk assessment – evaluate each asset for existing safeguards, severity of threats to each asset, and consequences of the threat
  - Recommendations – to reduce risk

© Cengage Learning 2014

Describing the Probability of Threats

Rating	What it means
Negligible	Unlikely to occur
Very Low	Likely to occur only two or three times every five years
Low	Likely to occur within a year or less
Medium	Likely to occur every six months or less
High	Likely to occur after a month or less
Very High	Likely to occur multiple times per month or less
Extreme	Likely to occur multiple times each day

Table 13-3 Describing the probability of threats

Describing Consequences

Description	Consequences
Catastrophic	Threatens the continuation of the program and causes major problems for customers
Major	Threatens the continuation of basic program functions and requires intervention by senior-level management
Moderate	Does not threaten the program; however, the program could be subject to major review and modification of operating procedures
Minor	Could threaten the program's efficiency or effectiveness but can be handled internally
Insignificant	Can be handled by normal operations

Table 13-4 Describing consequences

The Risk Analysis Process, Part 1

- Risk analysis is not a one-time activity
  - Evolves to account for an organization's changing size and activities
- Initial risk analysis is used to formulate a security policy
  - Policy is then enforced and security is monitored
- New threats and intrusion attempts
  - Create the need for a reassessment of the risk

© Cengage Learning 2014

The Risk Analysis Process, Part 2

- Risk analysis is a group of related activities that typically follow this sequence:
  - Holding initial team sessions – get groups of workers together in one place
  - Conducting asset valuation – identify assets to protect and determine their value
  - Evaluating vulnerability – investigate levels of threat and vulnerability in relation to value of assets
  - Calculating risk – after determining asset values, you can calculate risk

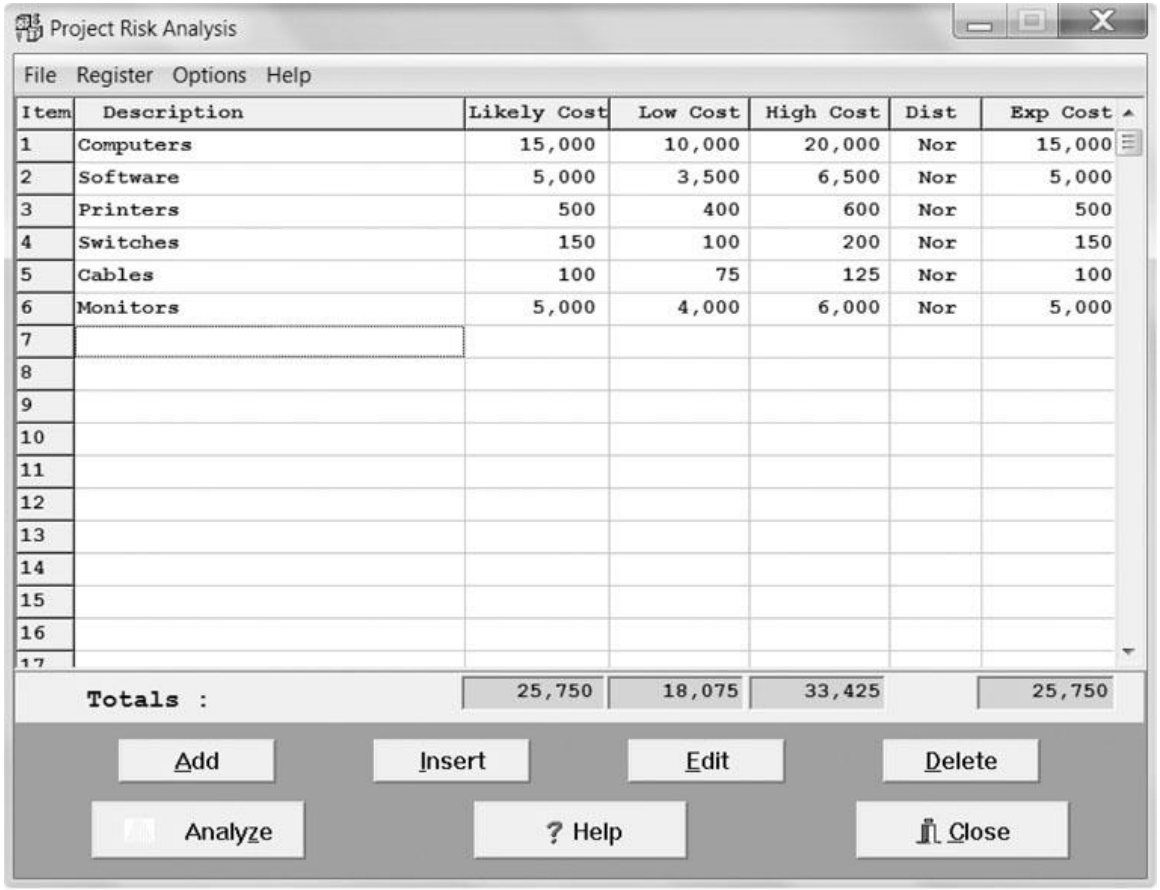
© Cengage Learning 2014

Analyzing Economic Impacts

- Estimating financial impact or losses
- You can use different statistics models
  - Or a software program such as
    - Project Risk Analysis by Katmar Software
- Basic information to estimate
  - Likely cost – most realistic estimate of replacement cost
  - Low cost – lowest dollar amount of replacement cost
  - High cost – highest dollar amount of replacement cost
- Monte Carlo simulation
  - Analytical method that simulates real-life system by randomly generating values for variables

© Cengage Learning 2014

Project Risk Analysis

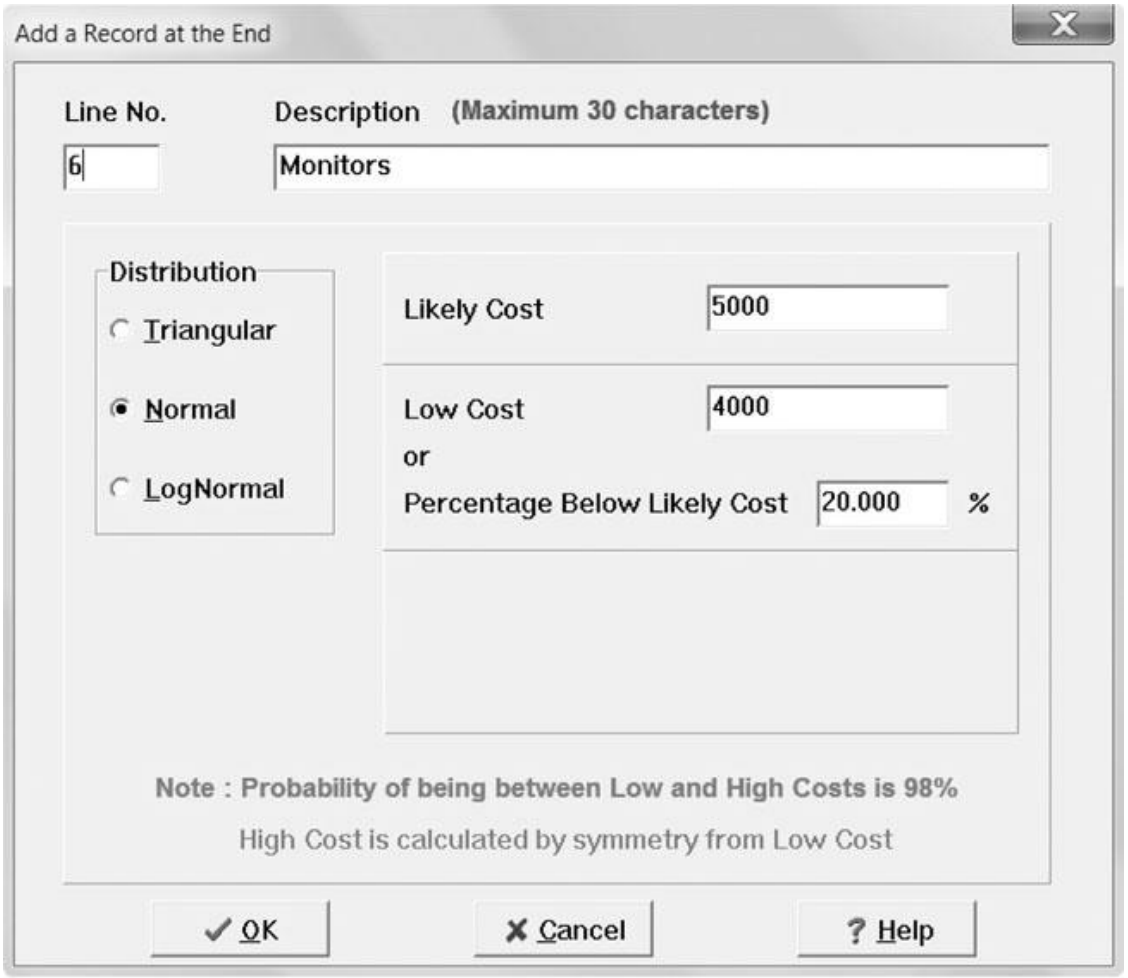


Item	Description	Likely Cost	Low Cost	High Cost	Dist	Exp Cost
1	Computers	15,000	10,000	20,000	Nor	15,000
2	Software	5,000	3,500	6,500	Nor	5,000
3	Printers	500	400	600	Nor	500
4	Switches	150	100	200	Nor	150
5	Cables	100	75	125	Nor	100
6	Monitors	5,000	4,000	6,000	Nor	5,000
7						
8						
9						
10						
11						
12						
13						
14						
15						
16						
17						
Totals :		25,750	18,075	33,425		25,750

Source: Katmar Software

Figure 13-4 Project Risk Analysis offers a structure for making cost estimates

Entering Values for Replacement Costs



Source: Katmar Software

Figure 13-5 Entering values for replacement costs

Techniques for Minimizing Risk

- **Risk management**: process of identifying, choosing, and setting up countermeasures for the risks you identify
  - Countermeasures should be incorporated into your security policy
- It is important to decide:
  - How to secure hardware
  - How to secure information databases in your network
  - How to conduct routine analysis
  - How to respond to security incidents

© Cengage Learning 2014

Securing Hardware

- Identify obvious types of physical protection
  - Such as environmental conditions
- Lock up hardware
  - Decide which devices you want to be locked
- Pay special attention to laptops
  - Laptops can be lost or stolen easily
- Install startup passwords and screen saver passwords
  - Experienced thieves can circumvent them though
- Use encryption to protect data

© Cengage Learning 2014

Conducting a Hardware Inventory

- Make a list of servers, routers, cables, computers, printers, and other hardware
  - Include your company's network assets
- Make a topology map of your network

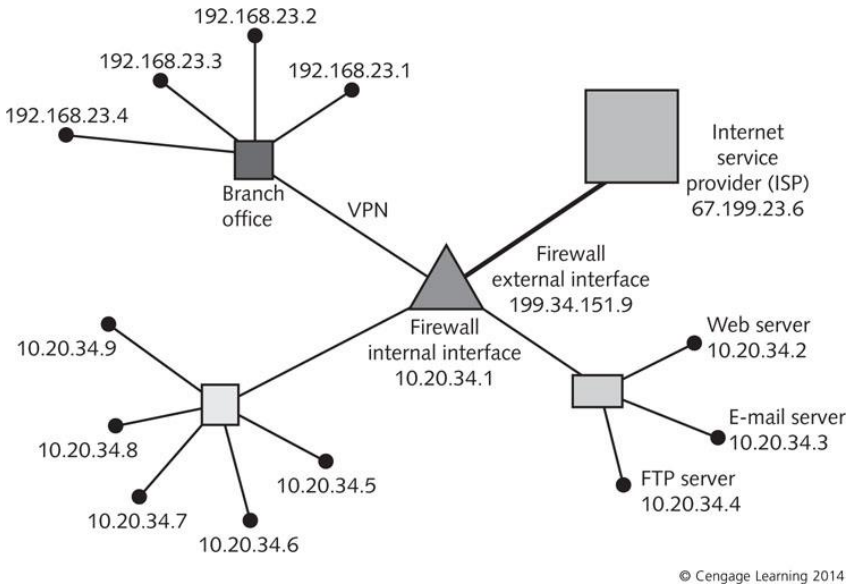


Figure 13-7 A topology map can supplement a hardware inventory

© Cengage Learning 2014

Ranking Resources To Be Protected

- Rank resources in order of importance
  - Values can be arbitrary numbers
- Focus your security efforts on most critical resources first
- Work in cooperation with your team and higher management

© Cengage Learning 2014

Using Encryption

- Encryption does not prevent intruders from accessing or viewing encrypted data
  - Can prevent data from being exploited
- Areas in which using encryption could be helpful in minimizing the risk of sensitive data being compromised:
  - Mobile computers
  - Removable media
  - Data transfers

© Cengage Learning 2014

Securing Information, Part 1

- Electronic assets
  - Word processing documents, spreadsheets, Web pages, and other documents
- Logical assets
  - E-mail messages, any records of instant messaging conversations, and log files
- Data assets
  - Personnel, customer, and financial information

© Cengage Learning 2014

Securing Information, Part 2

- Maintaining customer and employee privacy
  - Isolate critical information from the Internet
    - Move information from the original directory to a computer that is not connected to the Internet
    - Configure backup software to save critical files
  - Other measures
    - Encryption
    - Message filtering
    - Data encapsulation
    - Redundancy
    - Backups

© Cengage Learning 2014

Securing Information, Part 3

- Specify the following measures in a security policy:
  - Never leave company-owned laptops or handheld devices unattended
  - Always password-protect information on corporate devices
  - Encrypt any confidential information
  - Password-protect all job records and customer information
  - Restrict personnel information to human resources staff and/or upper management

© Cengage Learning 2014

Conducting Ongoing Risk Analysis

- Risk analysis is an ongoing process
  - Company's situation changes constantly
  - Risk analysis should be done routinely to include these changes
- Consider the following questions
  - How often will a risk analysis be performed?
  - Who will conduct the risk analysis?
  - Do all hardware and software resources need to be reviewed every time?
- Human emotions can influence risk evaluations
  - Some companies do not allow these calculations to be done manually

© Cengage Learning 2014

Examining the Concepts of Security Policies, Part 1

- Security policy is necessary if the organization falls into one of the following categories:
  - Employees work with confidential information
  - Damage, theft, or corruption of systems or data could result in severe financial loss
  - Organization has trade secrets
  - Employees regularly access the Internet
  - Company is subject to state or federal regulation for information security and privacy
  - Company uses Internet connections with partner businesses or application service providers (ASPs)

© Cengage Learning 2014

Examining the Concepts of Security Policies, Part 2

- Benefits of a security policy
  - Provides a foundation for an organization's overall security stance
  - Gives employees guidelines on how to handle sensitive information
  - Gives IT staff instructions on what defensive systems to configure
  - Reduces the risk of legal liability
- A good security policy is comprehensive and flexible
  - It is not a single document but a group of documents

© Cengage Learning 2014

General Best Practices for a Security Policy, Part 1

- Basic concepts
  - If it is too complex, no one will follow it
  - If it affects productivity, it will fail
  - It should state clearly what can and cannot be done on company equipment and property
  - Include generalized clauses
  - People need to know why a policy is important
  - Involve representatives of all departments
  - It should contain a clause stating the specific consequences for violating the policy

© Cengage Learning 2014

General Best Practices for a Security Policy, Part 2

- Basic concepts (continued)
  - Needs support from the highest level of the company
  - Employees must sign a document acknowledging the policy
    - And agreement to abide by it
  - Keep it updated with current technologies
  - Policy directives must be consistent with applicable laws

© Cengage Learning 2014

Developing Security Policies from Risk Assessment

- Steps to develop a security policy
  - Identify what needs to be protected
  - Define the threats faced by the network
  - Define the probability of those threats
  - Consequences posed by each threat
  - Propose safeguards and define how to respond to incidents
- Penalties for violating the policy are stated prominently near the top
- Policy effectiveness must be monitored

© Cengage Learning 2014

Teaching Employees About Acceptable Use

- The issue of trust is an integral part of a security policy
- Policy should define who to trust
  - And what level of trust should be placed in them
- Seek for a balance between trust and issuing orders
  - By placing too little trust in people and regulating everything they do in a rigid way, you might hamper their work, hurt morale, and increase odds that employees will circumvent security safeguards

© Cengage Learning 2014

Outlining Penalties for Violations

- Acceptable Use Policy – defines how employees should use the organization's resources
  - Should spell out what constitutes unacceptable use
    - Such as downloading or viewing objectionable or offensive content, using company equipment for personal business, and removing company property
- Policy should also contain guidelines for the penalty process
- Establish flexible methods of punishment
    - Can be applied at management's discretion

© Cengage Learning 2014

Criminal Computer Offenses

- Policy violations can become criminal offenses
- Subpoena
  - Order issued by a court demanding that a person appear in court or produce some form of evidence
- Search warrant
  - Similar to a subpoena
  - Compels you to cooperate with law enforcement officers conducting an investigation
- Security policy must state that an employee has no expectation of privacy while using company resources

© Cengage Learning 2014

Enabling Management to Set Priorities

- Policies give management a way to identify the most important security priorities
- Policy lists network resources that managers find most valuable in the organization
- Organizations who use remote commuting are more vulnerable to breaches and need to consider:
  - Value of information systems and the data in them
  - Threats the organization has encountered and will encounter
  - Chances that security threats will result in lost time and money

© Cengage Learning 2014

Dealing with the Approval Process

- Developing a security policy can take several weeks or several months
  - Take the time to do it right and cover all bases
- Policy needs to be reviewed and approved by upper management
  - You might encounter resistance
  - A security user awareness program can help

© Cengage Learning 2014

Feeding Security Information to the Security Policy Team

- Inform them of any change to the organization's security configuration
  - This team can suggest changes to the policy and determine whether new security tools need to be purchased
- Management's participation and backing can help in amending the security policy

© Cengage Learning 2014

Helping Network Administrators Do Their Jobs

- Policy can spell out spell but important information that an administrator would otherwise have to convey personally
- **Privileged access policy**
  - Policy that covers access that network administrators can have to network resources
  - Specifies whether they are allowed to
    - Run network-scanning tools
    - Run password-checking software
    - Have root or domain administrator access

© Cengage Learning 2014

Using Security Policies to Conduct Risk Analysis

- Design and implement a security policy
- Monitor your network behavior
  - Use this information in further rounds of risk analysis
- Conduct a risk analysis after a major change occurs
  - With each subsequent analysis, you have more real-world data for evaluating risk and its consequences

© Cengage Learning 2014

Steps to Creating a Security Policy

- Steps
  - Form a group that meets to develop the security policy
  - Determine whether the overall approach to security should be restrictive or permissive
  - Identify the assets you need to protect
  - Determine what needs to be logged and/or audited
  - List the security risks that need to be addressed
  - Define acceptable use of the Internet, office computers, passwords, and other network resources
  - Define security controls to be implemented
  - Create the policy

© Cengage Learning 2014

Identifying Security Policy Categories, Part 1

- Acceptable Use
  - Acceptable use policy: establishes how company resources must be used
  - Usually stated at the beginning of a security policy
  - Security user awareness program
    - Gets employees involved and excited about the policy
    - Explains how the policy benefits the employees

© Cengage Learning 2014

Identifying Security Policy Categories, Part 2

- Extranets and Third-Party Access
  - Extranet: private network that a company sets up as an extension of its corporate intranet
    - To allow contractors, suppliers, and external partners access to a limited portion of the network
  - Access should be permitted for business only
  - Third parties should be subject to security screening
  - Methods for allowing and denying should be defined
  - Duration of permitted access and details of terminating access should be defined
  - Penalties and consequences for violating access terms should be defined

© Cengage Learning 2014

Identifying Security Policy Categories, Part 3

- User Accounts, Password Protection, and Logical Access Controls
  - A security policy might include the following:
    - Users are not permitted to gain access to an unauthorized resource
    - Users cannot block an authorized user from gaining access to an authorized resource
    - Users cannot give their account usernames and passwords to other people for any reason
    - Users must protect their usernames and passwords in a secure location
    - Specifications regarding password characteristics

© Cengage Learning 2014

Identifying Security Policy Categories, Part 4

- Remote Access and Wireless Connections
  - Spells out the use of role-based authentication
    - Gives users limited access based on their roles and what resources a role is allowed to use
    - Access to confidential information may require two-factor authentication
      - Requires a combination of identifying physical property, a physical item, or using known information
  - Virtual Private Networks (VPNs)
    - Data is kept safe by the use of tunneling protocols and encryption

© Cengage Learning 2014

Identifying Security Policy Categories, Part 5

- Secure Use of the Internet and E-mail
  - Internet use policy can be integrated with an acceptable use policy
  - Covers how employees can access and use the Internet and e-mail
    - Prohibits broadcasting any e-mail messages
    - Spells out whether users are allowed to download software or streaming media from the Internet
    - Blocks any objectionable Web sites

© Cengage Learning 2014

Identifying Security Policy Categories, Part 6

- Network Security
  - Should clearly define and establish responsibilities for using the network and for protecting information that is processed, stored, and transmitted on the network
  - Network policy should describe the following
    - Applicability
    - Evaluations
    - Responsibilities
    - Commitment

© Cengage Learning 2014

Identifying Security Policy Categories, Part 7

- Server Security
  - Server security policy regulates IT staff who have privileged access to company servers
  - Policy should cover:
    - Names and positions of IT staff responsible for operating and maintaining servers
    - Specific identification for all servers
    - Username and password requirements
    - Configuration details
    - Monitoring requirements
    - Backup and system audit requirements
    - Policy compliance and enforcement

© Cengage Learning 2014

Identifying Security Policy Categories, Part 8

- Physical and Facility Security
  - Encompasses a broad range of issues related to locking down hardware components
  - Computer facility security must be integrated into the overall security policy for entire corporate facility
  - Common sense plays a major role in designing adequate physical security

© Cengage Learning 2014

Defining Incident Handling Procedures

- Security policy should state how you will respond to security incidents, what needs to be done in response, and why
- This portion of the security policy is called the incident response section
  - Describe the kinds of incidents to be addressed
    - Alarms sent by intrusion detection and prevention systems
    - Repeated unsuccessful logon attempts
    - Unexplained changes to data or deletion of records
    - System crashes
    - Poor system performance

© Cengage Learning 2014

Assembling a Response Team

- Security policy should identify which security staff need to be notified in case of an incident
- Security incident response team (SIRT)
  - Staff people designated to take countermeasures when an incident is reported
- SIRT contains
  - IT operations and technical support staff
  - IT application staff
  - Chief security officer
  - Information security specialists

© Cengage Learning 2014

Specifying Escalation Procedures

- Escalation procedure: set of roles, responsibilities, and measures taken in response to a security incident
- Incidents are usually divided into three levels:
  - Level One – minor to moderate
  - Level Two – major
  - Level Three – catastrophic
- Escalation procedures also specify employees that handle each level
  - Should also include stages of response that escalate along with incident's consequences

© Cengage Learning 2014

Responding to Security Incidents

- To determine how incidents should be escalated, the security policy's section on incident handling should clearly define incident types and level of escalation
  - Incident examples
    - Loss of passwords – Level One incident
    - Burglary or other illegal building access – Level Two incident
    - Property loss or theft – Level Two or Level Three incident

© Cengage Learning 2014

Including Worst-Case Scenarios

- Worst-case scenarios: descriptions of the worst consequences to an organization if a threat happens
  - Might be unlikely
  - Can help you determine the value of a resource at risk
- Values are derived from reasonable consequences of files, computers, and databases being unavailable for specified periods of time

© Cengage Learning 2014

Updating the Security Policy

- Update your policy
  - Based on the security incidents reported
- Any changes to the policy should be made available to the entire staff
  - By e-mail or posting the changes on the company's Web site or intranet
- Security policy should result in actual physical changes to the organization's security configuration
- Better protection means fewer internal or external incidents

© Cengage Learning 2014

Conducting Routine Security Reviews

- When reevaluating the organization's security policy, keep the following in mind:
  - Reviews need to be routine
  - Upper management must authorize reassessment schedule
  - Organization needs to respond to security incidents as they occur
  - Organization needs to revise the security policy because of incidents and other identified risks
- Policy should be flexible enough to allow "emergency" reassessments as needed

© Cengage Learning 2014

Summary, Part 1

- Risk Analysis plays a central role in defining a security policy
- Risk analysis covers company's computer hardware, software, and informational assets
- The first task is to identify assets that need protection
- Determine countermeasures for minimizing risk
- To perform a risk analysis, use an approach such as Survivable Network Analysis (SNA) or Threat and Risk Assessment (TRA)

© Cengage Learning 2014

Summary, Part 2

- A security policy provides a foundation for an organization's overall security stance
- Important to formulate a clear policy that explains employees' rights and how they should handle company resources
- Legal liabilities should be covered in a security policy
- If a security incident is caused by a criminal offense, it is important to understand your legal obligations and how to protect yourself from litigation

© Cengage Learning 2014

Summary, Part 3

- A security policy is often formulated as a series of specific policies rather than one long document
- A security policy should describe who responds to security incidents, what needs to be done, and why procedures are necessary
- An escalation procedure should be defined to determine who is notified during each type of incident
- Security policies should be reviewed and updated regularly

© Cengage Learning 2014